

Clinical Documentation Copilot

A Safety-First Reference Architecture for Grounded Clinical Documentation

Author

Manideep

Publication date

April 18, 2026

Evidence refresh

July 16, 2026

Document type

Research and engineering report

Purpose

This report specifies and evaluates a clinician-controlled reference workflow for grounded clinical note drafting. It combines reproducible synthetic-data evidence, explicit safety boundaries, interoperability mappings, and release-oriented verification requirements.

The repository is a reference implementation and research artifact. It is not a medical device, does not provide medical advice, and does not establish clinical efficacy or regulatory compliance.

EXECUTIVE SUMMARY

Abstract and key findings

Clinical documentation systems must reduce clerical work without weakening clinical accountability. This project implements a narrow drafting workflow in which appointment facts and the newest active treatment plan are the only permitted clinical sources. The default generator is deterministic: it structures supplied facts, preserves missing-information markers, and requires a clinician to review, edit, approve, and lock the record before completion.

2,837,098	2,928,115	12,352	8
Clinical-fact rows	All profiled CSV rows	Synthetic patients	Note-type contracts

Principal findings

- The benchmark records 2,837,098 clinical-fact rows, 2.84x the stated 1,000,000-row minimum.
- The integrity scan checked 2,928,115 rows and preserved 67 medication stop-before-start anomalies as warnings.
- The workflow fails closed when no current active treatment plan is available: voice is denied and generation is deferred.
- Selected protected fields are encrypted before SQLite persistence; the demonstration defaults are not production key management or full database encryption.
- FHIR R4 and SMART App Launch are integration targets. Direct clinical-document write-back is not claimed by the reference implementation.

Evidence boundary
Synthetic benchmark scale and code-level safeguards support reproducibility and engineering evaluation. They do not demonstrate real-world clinical adequacy, fairness, privacy compliance, or deployment security.

1. INTRODUCTION

Problem statement and scope

A documentation copilot operates at a consequential boundary: it transforms encounter evidence into text that may influence care continuity, billing, and legal records. The central design question is therefore not merely whether text can be produced, but whether the provenance, state, and human accountability of every draft remain visible and enforceable.

Research questions

Question	Operational interpretation
RQ1	Can note drafting be constrained to clinician-supplied facts and the newest active treatment plan?
RQ2	Can voice and generation policy be enforced below the user interface so bypass attempts fail closed?
RQ3	Can a public synthetic benchmark exceed one million clinical facts with traceable provenance and integrity checks?
RQ4	Can the application expose review, approval, revision, locking, and audit boundaries without claiming clinical validation?

In scope

- FastAPI reference API, encrypted field storage, role permissions, appointment state transitions, and deterministic note structuring.
- FHIR/SMART read-side mappings, an explicit future write-back boundary, synthetic benchmark profiling, and evidence artifacts.
- Eight distinct note-type schemas, text and transcript-derived fact workflows, review gates, and immutable completion behavior.

Out of scope

- Autonomous diagnosis, treatment recommendation, coding, billing determination, or unsupervised EHR submission.
- Claims of HIPAA compliance, clinical effectiveness, population representativeness, or production readiness.
- Distribution of MIMIC-IV or other credentialed data; restricted datasets are excluded from this public repository.

2. RESEARCH METHOD

Method and evidence model

The evaluation uses artifact-centered evidence: repository code defines policy behavior, structured JSON and CSV files record benchmark measurements, and a primary-source register supports standards and governance decisions. Reported counts are loaded directly from the evidence directory when this PDF is generated.

Evidence class	Loaded artifact	Interpretation rule
Dataset scale	evidence/dataset/row_counts.json and .csv	Headers excluded; distinguish clinical-fact rows from all relation rows.
Integrity	evidence/dataset/integrity_report.json	Report passed checks and warnings; do not silently repair source anomalies.
Provenance	evidence/dataset/source_receipt.json	Record source URL, archive checksum, extraction location, and synthetic-data status.
Automated tests	evidence/tests/test_inventory.json	Only inventory outcomes are reportable; absence is a pre-release placeholder.
Research basis	docs/research/references.json	Present titles, publishers, access dates, URLs, claims, and caveats in human-readable form.

Loaded evidence catalog

Artifact	Record summary
evidence/dataset/integrity_report.json	15 top-level fields
evidence/dataset/row_counts.csv	16 records
evidence/dataset/row_counts.json	14 top-level fields
evidence/dataset/source_receipt.json	12 top-level fields
evidence/tests/performance_results.json	8 top-level fields
evidence/tests/test_inventory.json	7 top-level fields
evidence/tests/test_summary.json	11 top-level fields

Temporal transparency

The publication date is fixed at April 18, 2026; the release evidence was refreshed on July 16, 2026. Each artifact retains its own generated or accessed timestamp, and later evidence must not be represented as having existed on the publication date.

3. SYSTEM DESIGN

Reference architecture

The architecture separates the clinician workspace, policy-enforcing application core, controlled adapters, persistence, and evidence collection. The separation allows plan selection, authorization, state transition, and voice controls to be checked at multiple boundaries.

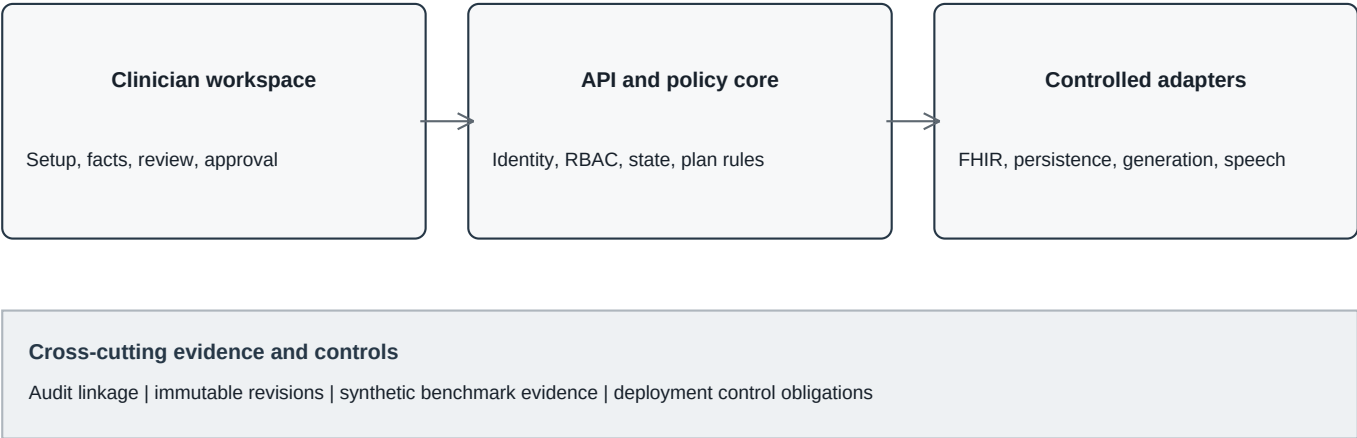


Figure 1. Logical architecture and cross-cutting control plane.

Deployment interpretation

- The browser is not trusted to select the authoritative treatment plan or grant itself permissions.
- The service resolves the newest effective active plan, binds its identifier to generation, and rechecks workflow state before approval and completion.
- External identity, FHIR, speech, inference, key management, database, backup, and monitoring services are adapter responsibilities in a production deployment.

Reference boundary
The current stack demonstrates domain controls locally. Organization-approved infrastructure, security operations, clinical governance, and privacy review remain deployment obligations.

3. SYSTEM DESIGN

Components and safety boundaries

Component	Primary responsibility	Enforced boundary
Clinician workspace	Setup, fact capture, review, edit, approval	Completion requires approved and validated content.
API and identity adapter	Validate gateway assertions, role, session, and inputs	Deny unauthenticated, expired, or unauthorized operations.
Workflow service	Manage status transitions and locks	Reject invalid transitions and completed-record mutation.
Plan policy	Select newest currently effective active plan	Ignore caller-selected historical plan identifiers.
Grounded generator	Structure allowed evidence into the note schema	Leave unsupported content explicitly missing.
Voice policy gateway	Validate plan state and transcript constraints	Reject voice workflow when active plan is absent.
Clinical repository	Store protected fields, revisions, receipts, and audit events	Encrypt selected fields and chain audit entries.
FHIR adapter target	Synchronize identity and care-plan state	Use idempotency and preserve upstream provenance.
Evidence pipeline	Profile synthetic data and collect release evidence	Keep real and restricted records out of the repository.

Trust boundaries

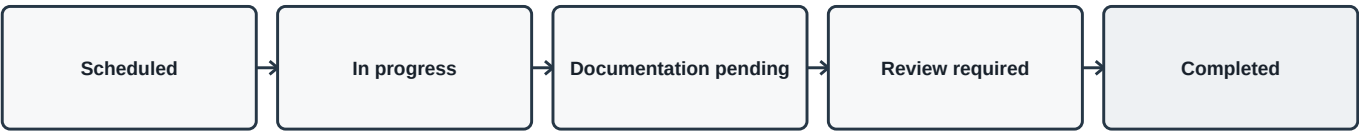
- Browser to API; application to EHR; services to persistence; voice capture to speech processing; generation adapter to inference runtime; and application events to monitoring.
- Every boundary requires explicit authentication, authorization, input limits, provenance, and failure behavior appropriate to the deployment.

Persistence precision

The reference repository applies Fernet authenticated encryption to selected text and JSON values before SQLite storage. SQLite pages, indexes, metadata, process memory, backups, and runtime secrets require additional deployment controls.

4. WORKFLOW

Appointment workflow and plan invariant



- Fail-closed branch** No active plan: facts may remain pending; voice and generation are denied.
- Terminal branch** Cancelled and completed appointments are locked against mutation.

Figure 2. Primary appointment state path and fail-closed branches.

Newest-active-plan invariant

Step	Rule
1	Filter to plans whose lifecycle status is ACTIVE.
2	Require effective_date on or before the decision date.
3	Require no expiration date or an expiration date on or after the decision date.
4	Order by effective date, upstream update timestamp, and local identifier, descending.
5	Select one newest plan; fail closed if none is eligible or equally current candidates remain.

State guarantees

- Six or seven unique clinician-supplied text facts can be stored while documentation waits for a current plan.
- Generated drafts retain plan and source-snapshot bindings; any later change requires regeneration before approval or completion.
- Generated missing-data markers prevent approval until the clinician supplies or explicitly resolves required content.
- Completed and cancelled appointments are terminal; the service rejects later mutation.

5. INTEROPERABILITY

FHIR R4 and SMART boundary

The interoperability design distinguishes read synchronization from clinical-document write-back. SMART App Launch with OAuth 2.0 and OpenID Connect is the intended authorization profile, while target-server capabilities and organization-specific profiles must be discovered and tested.

Local concept	FHIR R4 target	Mapping and caution
Client	Patient	Use issuer-qualified identifiers; do not deduplicate by name and birth date alone.
Staff	Practitioner / PractitionerRole	Resolve organization and permitted service role.
Appointment	Appointment / Encounter	Keep planned administrative status distinct from performed clinical interaction.
Treatment plan	CarePlan	Preserve lifecycle, period, goals, activities, version, and provenance.
Treatment goal	Goal or CarePlan.goal	Retain references and lifecycle status.
Approved document	Composition / DocumentReference target	Write only after EHR-specific profile, authorization, and reconciliation testing.
Audit	AuditEvent target	Keep local security audit separate from note narrative.

Synchronization semantics

- Upsert on issuer plus external identifier; record upstream version and lastUpdated for conflict detection.
- Process pages and retries idempotently; represent inactive or deleted upstream state as lifecycle change, not silent hard deletion.
- Quarantine ambiguous identifiers and equally current plans for review in a production adapter.

No write-back claim

The demonstrated export is user-controlled copy of an approved draft. A future direct write adapter must add capability discovery, conditional writes, duplicate prevention, provenance, error recovery, reconciliation, and a visible receipt.

Synthetic benchmark provenance

The benchmark uses the official MITRE Synthea COVID-19 10K CSV archive. Synthea records are synthetic; the repository does not include MIMIC-IV or other credentialed patient data. Raw benchmark files remain outside version control and are reproduced from the recorded source receipt.

Receipt field	Recorded value
Source	MITRE Synthea official sample-data repository
Archive	10k_synthea_covid19_csv.zip
Archive bytes	56,851,927
Archive SHA-256	559757dc849f4361a328f456d2c0a20c6df72419068321c753c6be787161e937
Downloaded at (UTC)	2026-07-16T04:29:01.723399+00:00
Extracted files	18
Synthetic data only	Yes
Restricted data included	No

Dataset selection rationale

- A public, reproducible artifact can include scripts and aggregate evidence without redistributing restricted health records.
- MIMIC-IV is excluded because access is credentialed and governed by a data-use agreement; its absence is a repository design decision, not a judgment about research value.
- Synthetic status removes patient privacy exposure from the benchmark itself, but it does not validate clinical safety or production security.

Terminology caveat
Synthea software is Apache-2.0 licensed, while embedded terminology content can have separate conditions. The repository NOTICE and the exact upstream revision must be reviewed for redistribution.

6. DATA

Dataset scale and relation profile

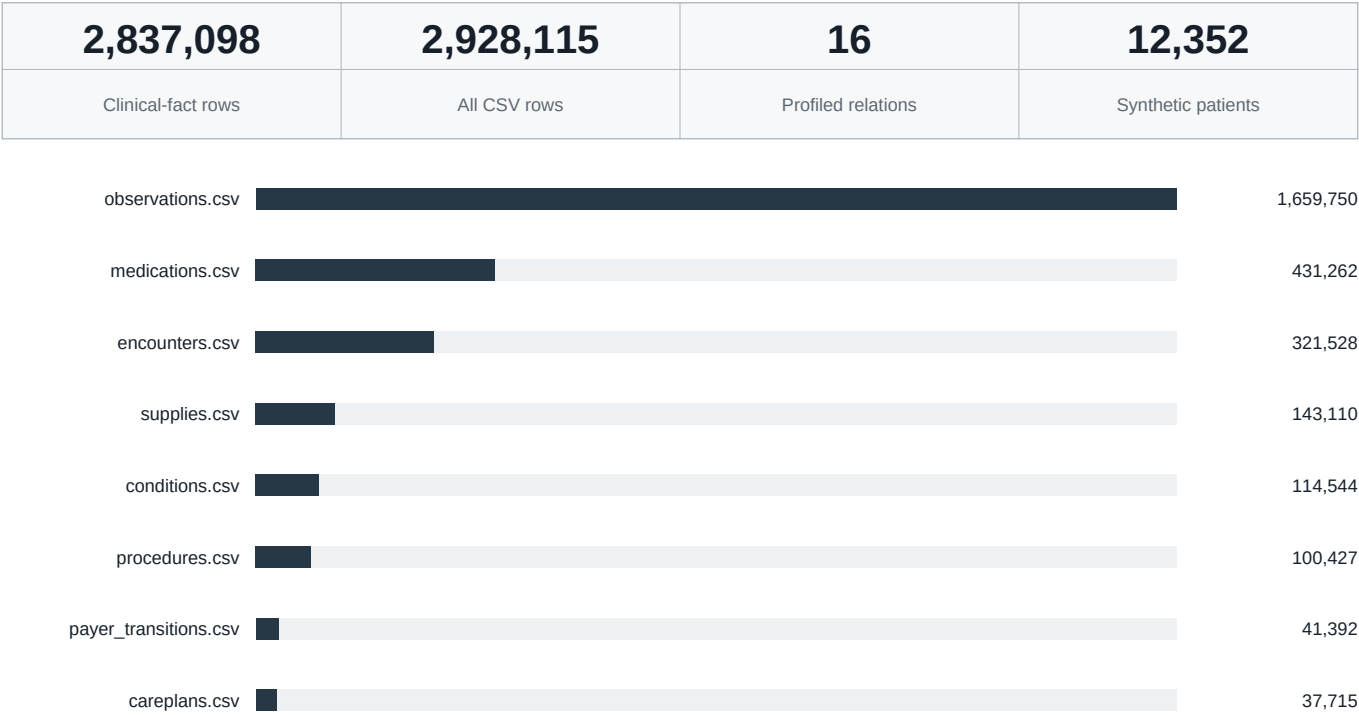


Figure 3. Eight largest profiled relations by header-excluded data rows.

Relation	Rows	Columns	Bytes
observations.csv	1,659,750	8	250,487,094
medications.csv	431,262	13	101,768,206
encounters.csv	321,528	15	99,706,700
supplies.csv	143,110	6	20,542,598
conditions.csv	114,544	6	14,116,480

Counting definition
Sum of data rows across extracted Synthea CSV relation files; headers excluded.

6. DATA

Integrity results and preserved anomaly

The integrity evidence reports successful referential, temporal, and core-identifier checks with a warning for a source anomaly. The anomaly is retained in the benchmark so downstream quarantine behavior can be evaluated instead of hidden by silent correction.

Check	Observed result
Overall status	passed_with_warnings
Rows checked	2,928,115
Patient foreign keys checked	2,878,490
Encounter foreign keys checked	2,472,082
Temporal ranges checked	809,029
Duplicate patient IDs	0
Duplicate encounter IDs	0
Recorded violations	{}

Observed source anomaly
The scan recorded 67 rows in medications.csv where STOP precedes START. The evidence policy is: Source anomalies are preserved and reported; operational ingestion should quarantine them.

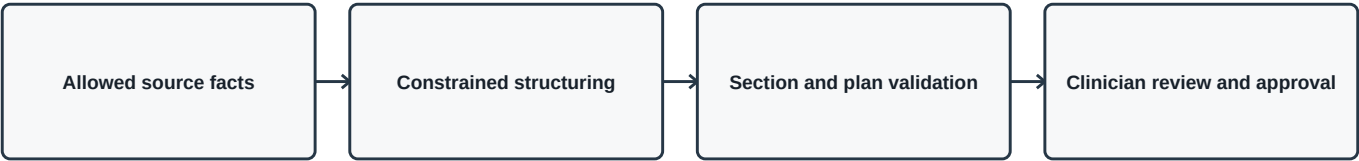
Operational treatment

- Do not rewrite the upstream benchmark while profiling; preserve checksums and original values.
- Quarantine anomalous records before operational ingestion and attach a machine-readable reason.
- Measure the effect of exclusion or correction separately and retain the decision trail.
- Do not interpret passed structural checks as evidence of clinical truth or population validity.

7. AI SAFETY

Grounded drafting safeguards

The default generator is deterministic rather than statistical. It receives an intentionally small evidence packet and adds labels, note sections, and explicit missing-data markers. Clinical propositions are copied from allowed sources rather than inferred.



Denied: unsupported diagnoses, quotations, symptoms, progress, interventions, risk findings, and outcomes.

Figure 4. Grounding, validation, and human-approval sequence.

Allowed input	Permitted use	Denied behavior
Appointment metadata	Document control and encounter context	No inference from staff name, service type, or date.
Newest active plan	Goals, objectives, and plan identifier	No historical or caller-selected plan substitution.
Six or seven text facts	Verbatim factual grounding	No instruction execution or added clinical claims.
Diarized transcript turns	Supplied speaker-attributed facts	No invented quotation or speaker attribution.
Missing markers	Require clinician completion	No fluent guess to conceal absent evidence.

Human control

- The draft is visibly a review artifact; generation does not equal approval or completion.
- Editing creates a new revision and clears prior review state; a clinician must review again.
- Completion locks the appointment, while later changes require a governed amendment workflow outside this reference scope.

7. AI SAFETY

Voice workflow and data-minimization controls

Voice is treated as a higher-risk optional path. The reference API accepts a supplied diarized transcript and duration metadata; it does not implement a raw-audio upload or production speech service. A local speech adapter is an architectural target, not a demonstrated clinical transcription capability.

Decision point	Reference behavior	Production obligation
Plan state	Voice allowed only when a current active plan is resolved server-side.	Recheck on every capture, upload, process, retry, and retention operation.
Minimum duration	Reject duration below 300 seconds without storing a transcript.	Validate whether the threshold is clinically and operationally appropriate.
Maximum duration	Schema caps duration at 14,400 seconds.	Add byte, codec, channel, and rate limits before receiving content.
Speaker coverage	Require both STAFF and CLIENT transcript turns.	Validate diarization quality and provide correction tools.
Raw audio	No raw-audio persistence path in the reference API.	Use consent, temporary storage, secure deletion, retention, and incident controls.
Generation	Transcript text is untrusted clinical data, never executable instructions.	Apply content isolation, provenance, monitoring, and clinician review.

Expired-plan invariant

When the current plan is absent or expired, the system must disable voice in the interface and reject the API request before accepting audio bytes or retaining transcript content.

Residual voice risks

- Consent ambiguity, bystander capture, diarization error, transcription error, local-device compromise, and temporary-file persistence remain deployment concerns.
- Human review must compare the draft to the encounter evidence; speaker labels are not proof that a quotation is correct.

8. DOCUMENTATION CONTRACTS

Eight note types: service and assessment

Every note type has a distinct section contract but shares the same grounding rule: use only appointment facts, the newest active plan, and clinician-supplied facts; mark unsupported information for clinician input.

Note type	Required sections	Safety-specific style rule
Case Management Note	Service Context; Treatment Plan Alignment; Services and Coordination; Client Response; Next Steps	Coordination and access; supplied services and response only.
Initial Child Assessment	Assessment Context; Presenting Information; Developmental and Family Context; Strengths and Needs; Plan	Developmentally appropriate and neutral; no inferred history.
Child Assessment Update	Update Context; Current Information; Changes Since Prior Assessment; Treatment Plan Alignment; Recommendations	Changes and progress require explicit source support.
Initial Adult Assessment	Assessment Context; Presenting Information; Relevant History; Strengths and Needs; Initial Plan	Separates supplied history from missing information.

Shared required fields

- Appointment date, service type, selected treatment goals, selected objectives, and supplied session facts.

Validation behavior

- An empty note or a note missing any required section is rejected by template validation.
- Generated missing-data markers intentionally force a clinician edit before approval.
- A probabilistic model, if later enabled, must remain behind the same source restriction, section validator, plan linkage, revision, and human-approval gates.

Template scope
A structurally valid template is not proof that a note is clinically complete, correct, billable, or appropriate for a particular organization.

8. DOCUMENTATION CONTRACTS

Eight note types: clinical updates and progress

Every note type has a distinct section contract but shares the same grounding rule: use only appointment facts, the newest active plan, and clinician-supplied facts; mark unsupported information for clinician input.

Note type	Required sections	Safety-specific style rule
Adult Assessment Update	Update Context; Current Information; Reported Changes; Treatment Plan Alignment; Plan	No unsupported comparison or clinical conclusion.
Counselor Note	Session Context; Goals and Objectives Addressed; Interventions; Client Response; Plan	Interventions and response require explicit support.
Evaluation and Management (E&M) Note	Encounter Context; History Supplied; Examination and Data; Assessment; Plan	Never infers examination, diagnosis, code, or medical decision making.
Nursing Progress Note	Encounter Context; Subjective Information; Objective Information; Nursing Actions and Response; Plan	Vitals, medication, assessment, and response must be supplied.

Shared required fields

- Appointment date, service type, selected treatment goals, selected objectives, and supplied session facts.

Validation behavior

- An empty note or a note missing any required section is rejected by template validation.
- Generated missing-data markers intentionally force a clinician edit before approval.
- A probabilistic model, if later enabled, must remain behind the same source restriction, section validator, plan linkage, revision, and human-approval gates.

Template scope
A structurally valid template is not proof that a note is clinically complete, correct, billable, or appropriate for a particular organization.

9. SECURITY

Security and privacy architecture

The reference implementation includes code-level safeguards but does not claim HIPAA compliance. Compliance depends on the deployed organization, risk analysis, policies, contracts, operations, infrastructure, and verified technical controls.

Control area	Implemented reference behavior	Additional deployment requirement
Identity	Trusted-gateway token, user ID, role, and session-expiry validation	Approved OIDC/SMART identity, TLS, secure cookies, lifecycle and reauthentication.
Authorization	Central role-permission matrix and protected endpoints	Least-privilege design, periodic access review, emergency access, and segregation of duties.
Confidentiality	Fernet encryption of selected text and JSON fields	Managed keys, rotation, full storage and backup encryption, memory and endpoint controls.
Integrity	Schema constraints, revision records, idempotency receipts, HMAC-chained audit entries	Append-only protected logging, monitoring, time integrity, retention, and independent verification.
Data minimization	No raw note text in intended audit metadata; no raw-audio persistence path	Logging review, redaction tests, retention schedules, secure deletion, and incident procedures.
Availability	Bounded input schemas and database transactions	Rate limits, capacity tests, backups, recovery objectives, continuity exercises, and failover.

Development-secret warning

The settings module includes local development defaults so the demonstration can run. Production must supply unique high-entropy secrets through an approved secret manager and must never reuse repository defaults.

Privacy engineering priorities

- Classify every field, minimize collection, bind purpose and retention, restrict audit access, test deletion, and prohibit PHI in logs, screenshots, fixtures, and error traces.

9. SECURITY

Threat model

The STRIDE analysis considers client identity, plan state, encounter facts, drafts, revisions, transient voice data, credentials, audit evidence, and role assignments across six trust boundaries.

Threat	Representative case	Primary controls	Verification focus
Spoofing	Reuse another clinician session	Gateway assertion, short session, target OIDC/SMART	Authentication and expiry denial tests
Tampering	Change plan identifier during generation	Server-side selection, plan binding, revisions	Plan-selection and mutation tests
Repudiation	Deny approval or export	Actor/time/action audit events	Audit integrity and authorization tests
Information disclosure	Sensitive content in logs or traces	Content-minimized audit, generic errors, encryption	Log scanning and error-path tests
Denial of service	Oversized transcript or repeated generation	Schema bounds, parsing limits, target throttling	Boundary, load, and recovery tests
Elevation of privilege	Counselor manages templates or syncs EHR	Central permission matrix, deny by default	Complete role-operation matrix

High-priority misuse cases

- UI bypass for expired-plan voice: API must reject before content retention.
- Historical-plan injection: service must ignore the caller-selected plan and resolve current state.
- Prompt-like text inside a bullet or transcript: treat it as untrusted data, not an instruction.
- Copy or complete unreviewed content: keep finalization unavailable until review, validation, and approval.
- Mutation of a terminal appointment: reject the change and retain prior revisions.

Residual clinical risk
No automated safeguard establishes clinical correctness. Incomplete facts, contextual mismatch, automation bias, and a model's unsupported output require qualified review, incident feedback, and a reliable disable mechanism.

10. VALIDATION

Verification strategy and release gates

Each high-risk rule needs both a success case and a denial case at the API or domain layer. User-interface behavior alone is insufficient because a caller can bypass disabled controls. The following matrix defines planned evidence categories; actual automated outcomes appear only when the test inventory artifact is present.

Area	Required success evidence	Required denial or boundary evidence
Plan policy	Newest effective active plan selected	Expired, inactive, missing, and ambiguous states fail closed
Grounding	Supplied facts and selected plan retained	Missing or malicious input adds no unsupported claim
Voice	Eligible diarized transcript accepted	Expired plan, too-short duration, invalid speakers, and oversized input rejected
State	Reviewed and approved note completes and locks	Unapproved completion and terminal mutation rejected
RBAC	Authorized role performs operation	Every non-permitted role-operation pair denied
Sync	Idempotent replay returns the same result	Request-ID reuse with changed payload conflicts
Data	Source receipt, hashes, counts, and threshold recorded	Schema, reference, temporal, uniqueness, and anomaly checks recorded
PDF	Exactly 24 pages with metadata and extractable text	Rendered-page review finds no clipping, overlap, or unreadable tables

Release gates

- Automated tests pass with no unexpected skips; evidence includes tool, timestamp, environment, and failure detail.
- Frontend builds and API starts; health behavior, security headers, repository secret scan, and tracked-file review are recorded.
- Raw data, recordings, databases, credentials, and sensitive samples are not tracked.
- The generated PDF passes page-count, metadata, text-extraction, and rendered visual review.
- Clinical validation remains a separate pre-deployment activity with qualified reviewers and acceptance criteria.

APPENDIX A

Automated test appendix 1 of 3

Inventory evidence contains 36 test records. Status totals: passed=36. Totals are descriptive only; release interpretation depends on the recorded status semantics and complete run metadata.

Inventory metadata: {"environment":{"node":"v22.19.0","npm":"10.9.3","platform":"macOS-26.5.2-arm64-arm-64bit-Mach-O","python":"3.13.3"},"generated_at_utc":"2026-07-16T05:05:40.996299+00:00","passed":true,"runs":[{"command":["\$PROJECT_ROOT/backend/.venv/bin/python","-m","pytest","-vv","-tb=short"],"cwd":"backend","duration_seconds":1.177,"exit_code":0,"name":"backend_pytest","started_at_utc":"2026-07-16T05:05:27.031924+00:00"},{"command":["\$PROJECT_ROOT/backend/.venv/bin/python","-m","compileall","-q","app"],"te...

# / ID	Name and coverage	Status / recorded metadata
1. tests/test_documentation_workflows.py::test_text_note_happy_path_grounding_review_approval_lock_and_history	test_text_note_happy_path_grounding_review_approval_lock_and_history FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
2. tests/test_documentation_workflows.py::test_expired_plan_disables_voice_and_defers_generation_until_new_plan	test_expired_plan_disables_voice_and_defers_generation_until_new_plan FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
3. tests/test_documentation_workflows.py::test_short_voice_transcript_is_rejected_without_storage	test_short_voice_transcript_is_rejected_without_storage FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
4. tests/test_documentation_workflows.py::test_text_summary_requires_six_or_seven_unique_facts	test_text_summary_requires_six_or_seven_unique_facts FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
5. tests/test_documentation_workflows.py::test_text_summary_preserves_source_bullets_byte_for_byte	test_text_summary_preserves_source_bullets_byte_for_byte FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
6. tests/test_documentation_workflows.py::test_cancelled_appointment_is_locked_against_restart	test_cancelled_appointment_is_locked_against_restart FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
7. tests/test_documentation_workflows.py::test_changing_source_facts_invalidates_the_existing_draft	test_changing_source_facts_invalidates_the_existing_draft FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
8. tests/test_documentation_workflows.py::test_plan_change_after_generation_requires_regeneration	test_plan_change_after_generation_requires_regeneration FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
9. tests/test_documentation_workflows.py::test_in_place_plan_update_invalidates_generated_snapshot	test_in_place_plan_update_invalidates_generated_snapshot FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
10. tests/test_documentation_workflows.py::test_heading_only_note_cannot_be_approved_or_completed	test_heading_only_note_cannot_be_approved_or_completed FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
11. tests/test_security_and_sync.py::test_health_is_non_sensitive_and_sets_security_headers	test_health_is_non_sensitive_and_sets_security_headers FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }
12. tests/test_security_and_sync.py::test_local_browser_origin_is_explicitly_allowed	test_local_browser_origin_is_explicitly_allowed FastAPI/domain workflow test	passed { "layer": "backend", "run": "backend_pytest" }

APPENDIX A

Automated test appendix 2 of 3

Continuation of the complete inventory: records 13 through 24.

# / ID	Name and coverage	Status / recorded metadata
13. tests/test_security_and_sync.py::test_oversized_declared_request_is_rejected_before_parsing	test_oversized_declared_request_is_rejected_before_parsing FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
14. tests/test_security_and_sync.py::test_production_rejects_missing_or_shared_secrets	test_production_rejects_missing_or_shared_secrets FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
15. tests/test_security_and_sync.py::test_identity_gateway_and_session_expiry_are_enforced	test_identity_gateway_and_session_expiry_are_enforced FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
16. tests/test_security_and_sync.py::test_role_permissions_deny_ehr_sync_to_clinician	test_role_permissions_deny_ehr_sync_to_clinician FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
17. tests/test_security_and_sync.py::test_client_sync_is_idempotent_and_request_ids_cannot_be_reused	test_client_sync_is_idempotent_and_request_ids_cannot_be_reused FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
18. tests/test_security_and_sync.py::test_latest_effective_active_plan_is_selected	test_latest_effective_active_plan_is_selected FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
19. tests/test_security_and_sync.py::test_equally_current_active_plans_fail_closed	test_equally_current_active_plans_fail_closed FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
20. tests/test_security_and_sync.py::test_all_eight_note_templates_expose_distinct_contracts	test_all_eight_note_templates_expose_distinct_contracts FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
21. tests/test_security_and_sync.py::test_stale_client_update_cannot_overwrite_newer_source_record	test_stale_client_update_cannot_overwrite_newer_source_record FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
22. tests/test_security_and_sync.py::test_protected_client_and_plan_fields_are_not_plaintext_in_sqlite	test_protected_client_and_plan_fields_are_not_plaintext_in_sqlite FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
23. tests/test_security_and_sync.py::test_audit_events_form_a_hash_chain_and_contain_no_client_names	test_audit_events_form_a_hash_chain_and_contain_no_client_names FastAPI/domain workflow test	passed {"layer":"backend","run":"backend_pytest"}
24. frontend-001	clinical documentation workspace > offers all eight organization note types Vitest UI workflow test in src/App.test.tsx	passed {"layer":"frontend","run":"frontend_vitest"}

APPENDIX A

Automated test appendix 3 of 3

Continuation of the complete inventory: records 25 through 36.

# / ID	Name and coverage	Status / recorded metadata
25. frontend-002	clinical documentation workspace > blocks voice and generation for an expired treatment plan while allowing facts to save Vitest UI workflow test in src/App.test.tsx	passed { "layer": "frontend", "run": "frontend_vitest" }
26. frontend-003	clinical documentation workspace > requires clinician review before approval and copy Vitest UI workflow test in src/App.test.tsx	passed { "layer": "frontend", "run": "frontend_vitest" }
27. frontend-004	clinical documentation workspace > invalidates a draft when source facts or note type change Vitest UI workflow test in src/App.test.tsx	passed { "layer": "frontend", "run": "frontend_vitest" }
28. frontend-005	clinical documentation workspace > does not carry edited facts from one client into another client Vitest UI workflow test in src/App.test.tsx	passed { "layer": "frontend", "run": "frontend_vitest" }
29. frontend-006	clinical documentation workspace > cancels an in-flight draft when the selected client changes Vitest UI workflow test in src/App.test.tsx	passed { "layer": "frontend", "run": "frontend_vitest" }
30. frontend-007	clinical documentation workspace > uses appointment details in the draft and invalidates it when they change Vitest UI workflow test in src/App.test.tsx	passed { "layer": "frontend", "run": "frontend_vitest" }
31. gate-backend_compile	Backend Compile Command completed with exit code 0 in 0.026 seconds	passed { "layer": "release-gate", "run": "backend_compile" }
32. gate-frontend_lint	Frontend Lint Command completed with exit code 0 in 0.475 seconds	passed { "layer": "release-gate", "run": "frontend_lint" }
33. gate-frontend_build	Frontend Build Command completed with exit code 0 in 0.927 seconds	passed { "layer": "release-gate", "run": "frontend_build" }
34. gate-python_dependency_audit	Python Dependency Audit Command completed with exit code 0 in 5.091 seconds	passed { "layer": "release-gate", "run": "python_dependency_audit" }
35. gate-node_dependency_audit	Node Dependency Audit Command completed with exit code 0 in 0.323 seconds	passed { "layer": "release-gate", "run": "node_dependency_audit" }
36. gate-api_performance	Api Performance Command completed with exit code 0 in 1.108 seconds	passed { "layer": "release-gate", "run": "api_performance" }

REFERENCES

References 1 of 2

1. **SYN-01. Synthea.** MITRE/Synthea. official project documentation. Accessed 2026-07-15.
<https://synthetichealth.github.io/synthea/>
2. **SYN-02. Synthea Patient Generator repository.** MITRE/Synthea. official source repository and README. Accessed 2026-07-15.
<https://github.com/synthetichealth/synthea>
3. **SYN-03. Synthea Downloads.** MITRE/Synthea. official data catalog. Accessed 2026-07-15.
<https://synthea.mitre.org/downloads>
4. **SYN-04. Synthea Apache License 2.0.** MITRE/Synthea. official software license. Accessed 2026-07-15.
<https://raw.githubusercontent.com/synthetichealth/synthea/master/LICENSE>
5. **SYN-05. Synthea NOTICE.** MITRE/Synthea. official attribution and third-party notice. Accessed 2026-07-15.
<https://raw.githubusercontent.com/synthetichealth/synthea/master/NOTICE>
6. **SYN-06. Synthea CSV File Data Dictionary.** MITRE/Synthea. official data dictionary. Accessed 2026-07-15.
<https://github.com/synthetichealth/synthea/wiki/CSV-File-Data-Dictionary>
7. **MIMIC-01. MIMIC-IV version 3.1.** PhysioNet/MIT Laboratory for Computational Physiology. official dataset access page. Accessed 2026-07-15.
<https://physionet.org/content/mimiciv/3.1/>
8. **FHIR-01. FHIR R4 RESTful API.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/http.html>
9. **FHIR-02. FHIR R4 Patient.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/patient.html>
10. **FHIR-03. FHIR R4 CarePlan.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/careplan.html>
11. **FHIR-04A. FHIR R4 Appointment.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/appointment.html>
12. **FHIR-04. FHIR R4 Encounter.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/encounter.html>
13. **FHIR-05. FHIR R4 Composition.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/composition.html>

REFERENCES

References 2 of 2

14. **FHIR-06. FHIR R4 Provenance.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/provenance.html>
15. **FHIR-07. FHIR R4 AuditEvent.** HL7 International. official standard. Accessed 2026-07-15.
<https://hl7.org/fhir/R4/auditevent.html>
16. **FHIR-08. FHIR Bulk Data Access: Bulk Data Export.** HL7 International. official implementation guide. Accessed 2026-07-15.
<https://hl7.org/fhir/uv/bulkdata/export.html>
17. **SMART-01. SMART App Launch 2.2: Launch and Authorization.** SMART Health IT/HL7 International. official implementation guide. Accessed 2026-07-15.
<https://hl7.org/fhir/smart-app-launch/STU2.2/app-launch.html>
18. **HHS-01. Summary of the HIPAA Security Rule.** U.S. Department of Health and Human Services, Office for Civil Rights. official regulatory guidance. Accessed 2026-07-15.
<https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>
19. **HHS-02. Guidance on Risk Analysis Requirements under the HIPAA Security Rule.** U.S. Department of Health and Human Services, Office for Civil Rights. official regulatory guidance. Accessed 2026-07-15.
<https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html>
20. **HHS-03. Guidance on HIPAA and Cloud Computing.** U.S. Department of Health and Human Services, Office for Civil Rights. official regulatory guidance. Accessed 2026-07-15.
<https://www.hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing/index.html>
21. **HHS-04. Minimum Necessary Requirement.** U.S. Department of Health and Human Services, Office for Civil Rights. official regulatory guidance. Accessed 2026-07-15.
<https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement/index.html>
22. **HHS-05. Are we required to certify our organization's Security Rule compliance?.** U.S. Department of Health and Human Services, Office for Civil Rights. official FAQ. Accessed 2026-07-15.
<https://www.hhs.gov/hipaa/for-professionals/faq/2003/are-we-required-to-certify-our-organizations-compliance-with-the-standards/index.html>
23. **NIST-01. NIST SP 800-66 Rev. 2: Implementing the HIPAA Security Rule—A Cybersecurity Resource Guide.** National Institute of Standards and Technology. official cybersecurity publication. Accessed 2026-07-15.
<https://csrc.nist.gov/pubs/sp/800/66/r2/final>
24. **NIST-02. Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1.** National Institute of Standards and Technology. official AI risk-management framework. Accessed 2026-07-15.
<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf>
25. **NIST-03. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1.** National Institute of Standards and Technology. official generative-AI risk profile. Accessed 2026-07-15.
<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

11. CONCLUSION

Limitations, roadmap, and conclusion

Limitations

- The benchmark is synthetic and focused on structural scale; it does not represent clinical diversity, prevalence, fairness, or real documentation quality.
- The deterministic generator demonstrates provenance-preserving structure, not natural-language quality, coding adequacy, or clinical usefulness.
- The local identity gateway, SQLite persistence, and transcript endpoint are demonstration scaffolding, not a production EHR, identity provider, speech service, or managed data platform.
- Direct EHR write-back, operational monitoring, deployment penetration testing, clinician validation, and privacy impact assessment remain incomplete.
- Automated test results are reportable only when evidence/tests/test_inventory.json is present and complete; any placeholder in Appendix A blocks a release claim.

Roadmap

Stage	Priority work	Exit evidence
1. Evidence maintenance	Refresh exhaustive inventories, builds, scans, benchmark checks, and PDF QA	Reconciled artifacts with timestamps, commands, environments, and failures
2. Adapter hardening	SMART discovery, issuer validation, idempotent paging, conflict and provenance behavior	Conformance and integration tests against approved sandboxes
3. Clinical validation	Representative cases, blinded review, error taxonomy, acceptance thresholds	Qualified governance approval with documented limitations
4. Deployment readiness	Managed identity, keys, storage, audit, monitoring, backup, incident and continuity controls	Organization risk acceptance and verified operational controls
5. Controlled pilot	Limited users, monitoring, disable path, feedback and amendment workflow	Pilot report with safety, usability, and incident findings

Conclusion

The project shows that a clinical documentation copilot can be designed around explicit source constraints, plan-aware failure behavior, visible human approval, immutable completion, and reproducible synthetic evidence. Its strongest contribution is the separation of demonstrated code behavior from deployment and clinical claims. The appropriate next step is adapter hardening and qualified validation, not autonomous use.

Authorship and use statement

Author: Manideep. Publication date: April 18, 2026. Evidence refreshed: July 16, 2026. This report describes a research reference implementation and must not be used as a substitute for clinical judgment, legal advice, security assessment, or regulatory review.